

Autenticação em *Web Banking* por Credenciais Biométricas Suportadas pelos Padrões de Serviços Web

Luciano R. Costa¹, Rafael R. Obelheiro¹ e Joni S. Fraga¹

¹Departamento de Automação e Sistemas
Universidade Federal de Santa Catarina
88040-900 – Florianópolis – SC – Brasil

{luciano, rro, fraga}@das.ufsc.br

Abstract. *The web banking channel has often been the target of attacks leading to banking fraud, making it necessary to reinforce user authentication mechanisms. The traditional credentials of knowledge and possession show some deficiencies that can be solved by biometric authentication. We present an implementation model for biometric authentication in web banking systems. The model uses the Web Services technology, which provides interoperability and facilitates the integration of legacy systems. The applicability of the model is verified by means of a prototype.*

Resumo. *O canal de atendimento web banking tem sido alvo de freqüentes ataques que levam a fraudes, o que exige reforço na autenticação de clientes. As credenciais tradicionais de conhecimento e posse apresentam algumas deficiências que podem ser supridas pela autenticação biométrica. Apresentamos um modelo de implementação para autenticação biométrica em sistemas de web banking. O modelo se utiliza da tecnologia de Serviços Web, que oferece interoperabilidade e facilita a integração de sistemas legados. A aplicabilidade do modelo é verificada através de um protótipo.*

1. Introdução

Os serviços bancários oferecidos por um banco de varejo típico são acessíveis através de uma variedade de canais de atendimento, como agências, máquinas de auto-atendimento e Internet. Dentre esses canais, destaca-se o *web banking*, que alia conveniência para os clientes e baixo custo para o banco. De fato, o número de transações bancárias pela *web* já supera o de transações realizadas nos caixas tradicionais [Febraban 2006]. A despeito dessa popularidade, o uso do canal *web* está sujeito a uma série de riscos, o que leva a grandes investimentos no sentido de melhorar a sua segurança. Um dos aspectos de segurança que tem recebido maior atenção é a autenticação dos usuários, um dos mais freqüentes alvos de fraudes bancárias. Os mecanismos tradicionalmente adotados para autenticação são credenciais de conhecimento (códigos e senhas) e de posse (cartões) [Sklira et al. 2003].

Estas credenciais possuem limitações, pois podem ser observadas, esquecidas ou perdidas. Além disso, elas não permitem vincular com suficiente grau de certeza uma transação ao indivíduo que a realiza. A autenticação biométrica é capaz de contornar essas deficiências: ela caracteriza unicamente um indivíduo e não pode ser esquecida ou perdida. O uso adequado de credenciais biométricas, possivelmente em conjunto com credenciais de conhecimento ou posse, pode aumentar significativamente a

segurança da autenticação de usuários de *web banking*. Este trabalho propõe um modelo de implementação para autenticação biométrica em sistemas de *web banking*. Este modelo possibilita que as vantagens das credenciais biométricas sejam aproveitadas sem negligenciar as suas limitações. Para integrar novos mecanismos de autenticação ao complexo ambiente computacional bancário, o modelo se utiliza da tecnologia de Serviços Web, que se caracteriza pela interoperabilidade e suporte a sistemas legados. A aplicabilidade do modelo é demonstrada usando um protótipo.

O artigo está organizado da seguinte forma. A seção 2 descreve o ambiente computacional bancário com ênfase nos sistemas de *web banking*. A seção 3 introduz conceitos básicos de sistemas biométricos e padrões que envolvem tecnologias biométricas, enquanto a seção 4 apresenta a tecnologia de Serviços Web e os padrões usados para garantir segurança nessa tecnologia. O nosso modelo para autenticação biométrica em sistemas de *web banking* e a sua implementação são discutidos na seção 5. A seção 6 discute trabalhos relacionados, e a seção 7 apresenta nossas conclusões.

2. Web banking

A figura 1 apresenta um modelo de alto nível da arquitetura de TI de um banco de varejo típico. Nela também se evidencia entre que camadas se mostra mais adequada a introdução de funcionalidades focadas na interoperabilidade, como é o caso das funcionalidades fornecidas por Serviços Web [Shan 2004]. Os elementos principais são:

1. Arquitetura técnica da empresa: lida com a arquitetura e a infra-estrutura no mais alto nível através da organização; exerce a governança, define políticas, estratégias e padrões corporativos; é responsável por todos os serviços estruturais, como *data centers*, rede corporativa, armazenamento, monitoração, gerenciamento do sistema e segurança.
2. Arquitetura intercanal: preocupa-se com as funcionalidades básicas e comuns, compartilháveis entre os diferentes canais de atendimento; lida com padrões de serviços, métodos de distribuição e gerencia uma infra-estrutura independente de canal, composta de recursos e aplicações relacionados a dados corporativos utilizáveis por todos os canais, como os dados de clientes, dados de agências, dados de produtos, entre outros.
3. Arquitetura do canal: lida com os requisitos de sistema, de segurança, de carga, de armazenamento, de capacidade, entre outros, específicos de um canal particular.
4. Aplicação (App): envolve os requisitos de negócios e características tecnológicas relacionados a cada aplicação específica.

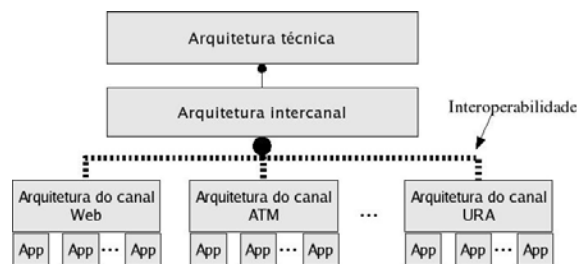


Figura 1. Modelo de alto nível da arquitetura da empresa

A dependência de sistemas legados é uma característica comum em ambientes computacionais bancários. Em geral, estes sistemas se constituem de bases de dados e

aplicações construídas ao longo de décadas, utilizando diversas tecnologias e arquiteturas, para atender a requisitos funcionais e de negócios. Estas aplicações legadas dificilmente poderiam ser portadas para outra plataforma, devido ao custo e ao risco inerentes, uma vez que são aplicações de missão crítica. Em termos do modelo da figura 1, podemos dizer que sistemas legados podem ser encontrados em todas as camadas, em especial na arquitetura intercanal.

Dentre os vários canais de atendimento disponíveis no ambiente bancário, o canal *web* merece destaque devido ao crescimento de sua utilização [Febraban 2006]. A figura 2 mostra um exemplo típico de aplicação do canal *web banking*. O usuário efetua o acesso a partir de um computador ligado à Internet usando um navegador *Web*. A rede do banco, embora complexa, pode ser modelada por meio um servidor *Web* que atende às requisições específicas para este canal e realiza o interfaceamento com os sistemas legados que implementam os serviços bancários. A comunicação entre o cliente e o servidor *Web* é protegida por um canal SSL (*Secure Sockets Layer*), que garante a confidencialidade, integridade e autenticidade do tráfego. É muito comum a utilização de *applets* Java no lado cliente, o que permite a implementação de funcionalidades mais sofisticadas e seguras (por exemplo, estabelecimento de cifragem fim a fim entre o cliente e o serviço legado de transações bancárias), além de facilitar a manutenção e distribuição do código da aplicação pelo banco. Apesar disso, a vulnerabilidade do ambiente computacional do cliente e o desconhecimento de noções de segurança por parte dos usuários dificultam a tarefa de garantir a segurança nesta ponta da transação.

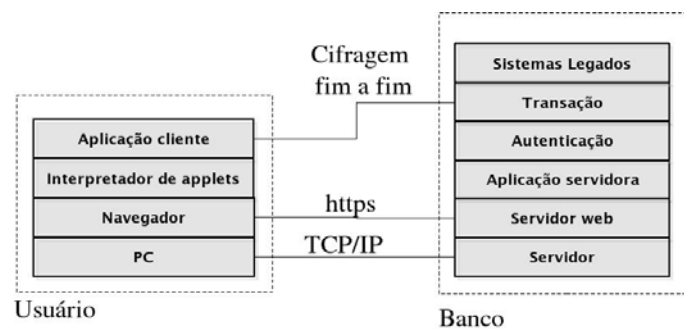


Figura 2. Um exemplo de aplicação de *web banking*.

Dentre os aspectos de segurança relacionados a sistemas de *web banking*, um dos mais importantes é a **autenticação de usuários** [Gupta et al. 2004]. Tipicamente, essa autenticação usa uma combinação agência/conta/senha. Em muitos casos, a senha do canal *web* é diferente da senha do cartão magnético, podendo substituir esta última ou complementá-la. Além dessas credenciais, ditas **de conhecimento**, alguns bancos estão adotando também soluções baseadas em **credenciais de posse**, tais como:

- cadastramento prévio dos endereços IP dos computadores usados pelo cliente;
- distribuição de cartões contendo um conjunto de códigos, os quais serão usados a cada acesso, um de cada vez, uma única vez, em ordem pré-estabelecida (esquema de *one-time password*); e,
- distribuição de certificados digitais que precisam ser apresentados a cada acesso.

Embora estas soluções aumentem a segurança da autenticação, elas são insuficientes para vincular o acesso ao sistema a uma pessoa específica, pois as credenciais utilizadas podem

ser repassadas ou emprestadas. Sistemas biométricos de autenticação procuram vincular unicamente um indivíduo com suas credenciais biométricas. Adequadamente implementados, podem aumentar significativamente a confiança na autenticação de usuários.

3. Sistemas Biométricos

Os sistemas biométricos são usados para a **autenticação de pessoas**. A figura 3 ilustra um sistema biométrico, no qual o usuário é previamente registrado e seu **perfil** biométrico fica armazenado. Quando da utilização posterior do sistema, o processo de aquisição obtém um novo exemplar dos dados biométricos apresentados pelo usuário. Características particulares (atributos) do exemplar são extraídas. O processo de comparação obtém um escore que representa a similaridade entre os atributos extraídos e o perfil registrado. Caso a similaridade obtida seja superior a um **limiar de comparação** estabelecido previamente, o exemplar é considerado coincidente com o perfil [Costa et al. 2006].

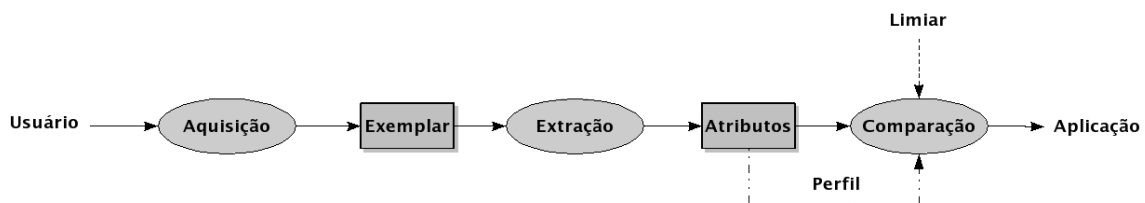


Figura 3. Modelo conceitual simples de um sistema biométrico, mostrando os processos principais e seus produtos.

Existem basicamente dois modos de autenticação biométrica: a **verificação** e a **identificação** [Bolle et al. 2004, p. 25]. Na verificação, um usuário informa sua identidade (através de um código, por exemplo) e apresenta sua característica biométrica, e o sistema verifica se esta característica corresponde à identidade fornecida. Na identificação, o usuário apresenta apenas sua característica biométrica, e o sistema varre a base de perfis para descobrir a quem pertence a característica fornecida. Como a autenticação biométrica está sujeita a imprecisões, geralmente a abordagem por identificação produz uma lista de pessoas cujas características biométricas sejam suficientemente similares à apresentada, e esta lista deve ser então refinada por um processo adicional (automatizado ou manual).

Qualquer característica fisiológica ou comportamental humana pode ser usada como identificador biométrico. As tecnologias biométricas mais utilizadas se valem da aparência da face, do padrão das impressões digitais, do formato da mão, do padrão da íris, do padrão de voz e das características dinâmicas da assinatura manuscrita (figura 4). O sucesso de um identificador biométrico repousa na sua maior capacidade de satisfazer a alguns requisitos de universalidade, unicidade, permanência, coleta, aceitação, precisão e resistência à fraude. Os diversos exemplares da mesma característica biométrica, da mesma pessoa, não são exatamente os mesmos, uma vez que mudanças nas condições do usuário (como estado emocional, estado físico, pressa), mudanças nas condições do ambiente (como iluminação, umidade, ruído) e mudanças nas condições do sensor alteram a qualidade dos dados adquiridos. Assim, qualquer sistema biométrico está sujeito a imprecisões, e a quantificação destas imprecisões ou erros, não pode ser determinada de forma exata, mas somente por estimativas estatísticas dos erros, que são expressos em taxas e percentagens.

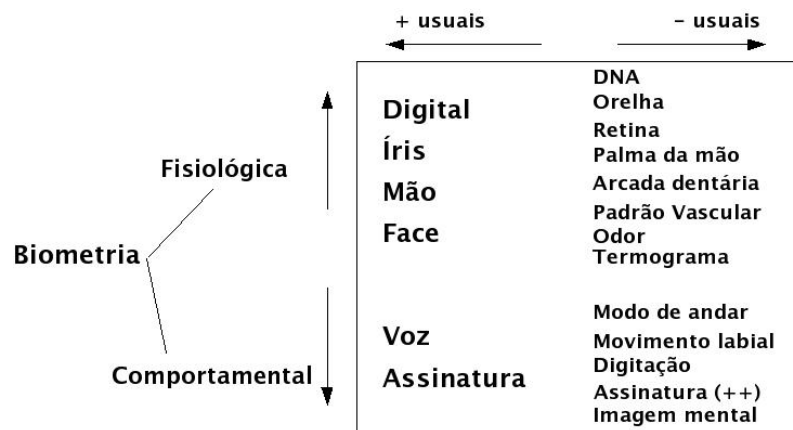


Figura 4. As seis características biométricas mais comuns e outras, que são usadas com menor frequência ou que estão em estágios iniciais de pesquisa. As características fisiológicas (estáticas) dependem principalmente da carga genética e as comportamentais (ou dinâmicas) dependem ainda fortemente do aprendizado e da experiência.

Um sistema biométrico pode ser calibrado para trabalhar com maior ou menor rigor, de acordo com o ajuste do limiar de comparação, o que produz taxas de erros que possuem conseqüências opostas. Um sistema mais permissivo, com limiar baixo, tem aumentada sua falsa aceitação (FA), que resulta em brechas na segurança, com a admissão de usuários não autorizados. Por outro lado, um sistema mais rigoroso, com limiar alto, tem aumentada sua falsa rejeição (FR), o que resulta em problemas de conveniência, já que usuários genuínos terão acesso negado até uma verificação posterior.

Padrões também são importantes para a interoperabilidade, o crescimento e a aceitação das tecnologias biométricas. Os mais representativos para este trabalho são:

- **BioAPI**¹: proposto por um consórcio de empresas, define uma interface padronizada para dispositivos e sistemas biométricos. Por exemplo, dispositivos diferentes que seguem a BioAPI usam a mesma operação proposta na interface para capturar um exemplar biométrico.
- **X9.84** [ANSI 2003]: fornece linhas gerais para a implementação segura de sistemas biométricos em instituições financeiras, incluindo especificações para a segurança do equipamento usado, o gerenciamento dos dados, a aplicação da tecnologia para controle de acesso físico e lógico e técnicas para transmissão e armazenamento seguros dos dados biométricos.
- **CBEFF** [NIST 2001]: proposto pelo NIST, define a estrutura básica de um registro de dados biométrico genérico. Organizações que desenvolvem especificações ou dispositivos em conformidade com o CBEFF registram junto a uma autoridade centralizada (IBIA, *International Biometrics Industry Association*) os seus formatos específicos que são então disponibilizados, mediante um custo, a partes interessadas (usuários dessas especificações ou dispositivos). Os padrões BioAPI e X9.84 definem objetos biométricos compatíveis com o CBEFF.
- **XCBF** (*XML Common Biometric Format*): esquema XML da OASIS² que representa o padrão CBEFF, descrevendo também mecanismos e técnicas para a inte-

¹BioMetric Application Programming Interface, disponível em <http://www.bioapi.org/>.

²XCBF, XACML, SAML e WS-Security são especificações da OASIS (*Organization for the Advancement of Structured Information Standards*), relacionadas a este trabalho, e estão disponíveis em

gridade dos dados, autenticação da origem e privacidade dos dados biométricos em sistemas e aplicações baseados em XML, como é o caso dos Serviços Web.

4. Padrões de segurança para Serviços Web

Com a disseminação de serviços pela Internet, as empresas também passaram a perceber os benefícios que poderiam ser auferidos através da interação de seus sistemas computacionais com os sistemas de organizações parceiras como clientes e fornecedores, notadamente em relações como B2B (*business-to-business*) e B2C (*business-to-consumer*). Entretanto, a natural incompatibilidade entre sistemas que não foram originalmente projetados para suportar tais interações apresenta desafios à implementação desse tipo de relação. Diante desse cenário, foram propostas tecnologias com o objetivo de viabilizar a construção de aplicações distribuídas facilitando a integração dos sistemas já existentes. Os Serviços Web (WS) são uma das mais recentes e mais promissoras dessas tecnologias integradoras. Fundamentalmente, a tecnologia WS baseia-se na definição de **serviços**, que representam processos de aplicação, e de **documentos XML**, que encapsulam a informação processada e transmitida pelos serviços. A interoperabilidade decorre da definição de padrões adequados à orientação a serviços e do uso de outros amplamente estabelecidos, como XML e HTTP.

A exposição dos sistemas computacionais de uma organização (e das informações que eles processam) através de Serviços Web suscita naturalmente preocupações com a segurança. Visando a minimizar tais preocupações, foram elaborados diversos padrões de segurança para WS. A principal especificação de segurança relacionada a Serviços Web é a WS-Security (da OASIS), que descreve melhorias e extensões nas mensagens SOAP (SOAP é um protocolo para troca de mensagens XML usado em WS) para agregar as propriedades de confidencialidade (com base na XMLEncryption) e integridade (com base na XMLSignature). A especificação WS-Security visa garantir a segurança fim a fim no nível da mensagem e não somente no nível de transporte, possuindo três pontos principais: (1) credenciais de segurança que podem ser incluídas nas mensagens SOAP com informações de autenticação; (2) integridade da mensagem pela inclusão na mensagem SOAP de informações relacionadas a assinaturas digitais de toda ou de parte da mensagem; e, (3) confidencialidade da mensagem, pela cifragem total ou de partes da mensagem.

O esquema XML definido nas especificações WS-Security permite vários elementos `<wsse:Security>` dentro da mensagem SOAP. O conjunto de especificações XCBF, para troca de dados biométricos (seção 3), pode ser usado dentro das especificações WS-Security, segundo publicação da OASIS (*Web Services Security XCBF Token Profile*). O modelo de processamento para WS-Security com objetos XCBF não é diferente de outros formatos de *token* descritos no WS-Security. Objetos XCBF devem ser anunciados utilizando `<wsse:XCBFSecurityToken>` dentro do cabeçalho da mensagem SOAP. Os atributos do *token* são usados para indicar características do conteúdo do mesmo para a aplicação que processa o WS-Security. O processamento da biometria, da assinatura e da cifragem de objetos XCBF não é parte do modelo de processamento WS-Security, devendo ser tratados por manipuladores adicionais ligados à biometria. O exemplo da figura 5 ilustra uma mensagem SOAP cujo cabeçalho (linhas 2-12) contém um *token*

de segurança XCBF (linha 4). Neste exemplo, o `XCBFSecurityToken` contém um objeto biométrico desprotegido, ou seja, nem cifrado e nem assinado (linha 6). Os dados biométricos (linha 9) são codificados em uma representação ASCII para transferência.

```

1 <S:Envelope xmlns:S="...">
2   <S:Header>
3     <wsse:Security xmlns:wsse="...">
4       <wsse:XCBFSecurityToken
5         xmlns:wsse="http://schemas.xmlsoap.org/ws/2002/04/secext"
6         Id="biometric-objects"
7         ValueType="wsse:XCBFv1"
8         EncodingType="wsee:DER">
9         MIEZzMJMzCCA9CzPHGzAwIBA ...
10      </wsse:XCBFSecurityToken>
11    </wsse:Security>
12  </S:Header>
13  <S:Body> ... </S:Body>

```

Figura 5. Exemplo de mensagem SOAP contendo um token XCBF.

A WS-Trust [WS-Trust 2005] é uma especificação que procura fornecer um ambiente confiável para os Serviços Web. Trata-se de um esforço que visa principalmente a troca de credenciais de segurança, para que possibilite a comunicação através de diferentes domínios de segurança. A especificação descreve as relações de confiança que podem ser estabelecidas: (1) direta, quando o domínio A confia nos atributos oriundos do domínio B; e (2) mediada, quando os domínios A e B possuem relações de confiança com um domínio C, mas não possuem relações entre si. Os STSs (*Security Token Services*) introduzidos na especificação WS-Trust como as autoridades responsáveis por emitir os atributos de credenciais. O próprio STS é um *web service*, e a comunicação com o mesmo se dá por meio de um protocolo de pedidos e respostas: RST (*RequestSecurityToken*) e RSTR (*RequestSecurityTokenResponse*). Os atributos de segurança emitidos pelo STS consistem em asserções SAML (*Security Assertion Markup Language*, da OASIS).

Numa visão bastante concreta, SAML é um conjunto de especificações e esquemas XML para troca de informações de segurança, expressas na forma de asserções de segurança de três tipos: (1) asserções de autenticação realizadas por um sujeito, expressando, por exemplo, que a autenticação se deu sobre um mecanismo de segurança específico, com base em uma informação de identificação particular e num dado instante; (2) asserções de atributos atestando o valor de um ou mais atributos do sujeito, como o número do cartão de crédito ou a descrição do último serviço realizado pelo sujeito; e, (3) asserções de autorização que atestam que serviços o sujeito está autorizado a realizar [Kearney et al. 2004].

Para verificar se as asserções emitidas pelo STS embutem credenciais que permitam ativar serviços, é necessário consultar uma política de autorização no sistema. Geralmente, cada sistema se vale de linguagens próprias para a definição de políticas de autorização. Para promover a interoperabilidade, foi introduzida a XACML (*eXtensible Access Control Markup Language*, da OASIS) fornecendo: (1) uma linguagem para políticas de controle de acesso, utilizada para definir quem possui acesso sobre que recursos; e, (2) o formato das requisições e respostas usadas para efetuar consultas à política de

autorização. Este formato de requisições e respostas define as trocas entre o PEP (*Policy Enforcement Point*) e o PDP (*Policy Decision Point*) [Yavatkar et al. 2000]. O PDP é a entidade que toma a decisão de autorização. Para tanto, avalia os atributos do requisitante, da operação e do recurso solicitado, com base em uma política de autorização. O PEP, por sua vez, é a entidade que aplica a decisão de acesso tomada pelo PDP. Desta forma, estas entidades atuam em conjunto para concretizar a política de autorização do sistema. Um pedido é composto por: (1) atributos do sujeito que origina a requisição; (2) identificação do recurso desejado; (3) ações que serão executadas no recurso; e, (4) atributos do ambiente [Mello et al. 2006].

5. Modelo para Autenticação Biométrica em Web Banking

5.1. Modelo Conceitual

A figura 6 apresenta o modelo proposto para um serviço de *web banking* com autenticação biométrica. Em linhas gerais, um cliente pretende utilizar um serviço que fornece acesso a um recurso, como uma transação bancária. Antes de requisitar o serviço, o cliente precisa se autenticar no sistema. A **autoridade de autenticação** assegura que o cliente se autenticou em um determinado instante usando um método específico de autenticação. Após o processo de autenticação, o cliente recupera atributos de credencial que estão armazenados no sistema (como o seu nome e CPF) e que são usados para determinar se o mesmo possui direito de acesso ao recurso. A emissão desses atributos é responsabilidade da **autoridade de atributos**.

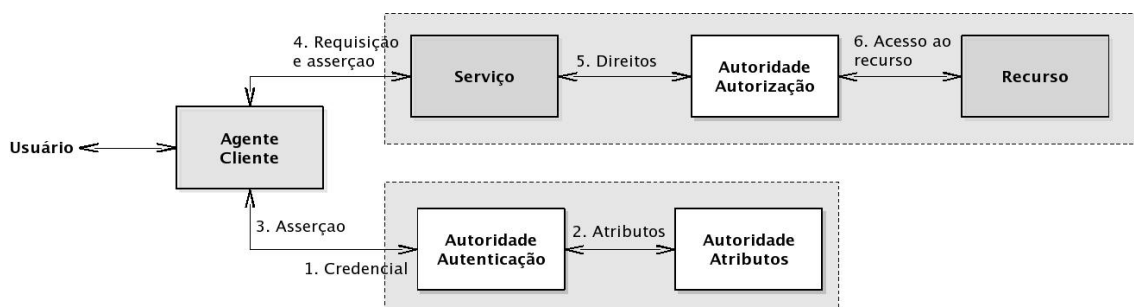


Figura 6. Modelo utilizado para descrever o caso de *web-banking*.

Tipicamente, um serviço de *web banking* é estruturado em pacotes de serviços adequados ao nível de confiança oferecido pela autenticação do usuário. Um usuário não autenticado pode ter acesso a serviços básicos, como informações, consultas e solicitações. No espaço autenticado, o usuário que apresenta uma credencial comum tem acesso a um pacote de serviços básicos, como saldos, extratos e transferências de pequeno valor. Já para um usuário que oferece informação de identificação especial, o processo de autenticação fornece um nível maior de confiança, o que permite a disponibilização de serviços de maior risco, como transferências de grandes valores, por exemplo. A decisão de qual pacote de serviços está disponível para um usuário do sistema é responsabilidade da **autoridade de autorização**, que se vale para isso das informações fornecidas pelas autoridades de autenticação e de atributos.

O funcionamento do modelo se baseia na seguinte dinâmica, ilustrada na figura 6. O agente cliente, após a captura, envia a informação biométrica do usuário para a autoridade de autenticação, que verifica a validade da mesma (1) e recupera atributos do mesmo

(2). Caso a informação biométrica do usuário seja válida, a autoridade de autenticação fornece ao agente cliente credenciais para apresentar aos mecanismos de controle de acesso (3). Após esta autenticação inicial, o agente cliente busca a execução do serviço desejado, por meio do envio de uma requisição acompanhada da asserção de autenticação (4). A autoridade de autorização verifica a validade das credenciais do requisitante do serviço e se o agente cliente possui a autorização necessária para a realização do serviço (5). A relação de confiança dentro do domínio do banco é direta, ou seja, existe confiança entre as autoridades de autenticação e de autorização. O serviço desejado é então executado, com base na decisão da autoridade de autorização (6).

5.2. Mapeamento do modelo em padrões de Serviços Web

O modelo conceitual apresentado da seção anterior é mapeado em uma arquitetura orientada a serviços, como mostrado na figura 7. O usuário é representado por um **agente**

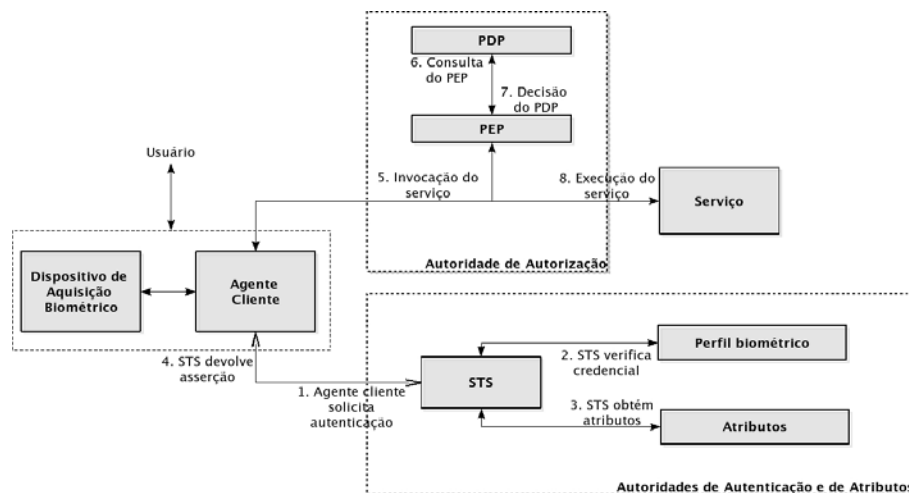


Figura 7. Modelo de implementação usando Serviços Web. O agente cliente é direcionado ao STS (1), que verifica a credencial do usuário (2), recupera seus atributos (3) e emite uma asserção de autenticação (4). O agente cliente invoca o serviço (5), que, com base na decisão de autorização (6 e 7), é executado (8).

cliente, que é um *proxy* para intermediar as interações do usuário com os Serviços Web. As autoridades de autenticação e de atributos são implementadas por um STS (definido na especificação WS-Trust) e que é responsável por emitir, validar e trocar credenciais de segurança, representadas neste modelo por asserções SAML. O papel de autoridade de autorização é assumido pelo conjunto PEP/PDP da especificação XACML: o PDP toma a decisão de autorização, com base nas credenciais do cliente e na política de autorização definida para o recurso, e o PEP aplica a decisão tomada pelo PDP. A figura 7 também ilustra a dinâmica de funcionamento do modelo de implementação, cujos passos são detalhados na tabela 1.

No modelo introduzido, a autenticação de usuários junto ao banco se dá por meio do processo de verificação biométrica (seção 3), fazendo uso da tecnologia baseada em **impressão digital**. A utilização da impressão digital é justificada pelos seus pontos fortes: (1) esta tecnologia proporciona suficiente precisão para trabalhar com sistemas de verificação de larga escala; (2) existe uma longa tradição legal no uso da impressão digital como identificador imutável; (3) as impressões digitais dos vários dedos da mão são

diferentes e as impressões digitais de gêmeos idênticos são diferentes; (4) a impressão digital pode ser colhida facilmente a baixo custo; e, (5) os sensores podem ser pequenos e portáteis, apropriados para um sistema de *web banking* e já existem até mesmo sensores de impressão digital embutidos em *smart cards*.

Passos	Descrição
1. O agente cliente solicita autenticação	O agente cliente solicita autenticação, por meio do envio de uma mensagem SOAP, contendo um RST. Os dados do exemplar biométrico são encapsulados em um objeto XCBF. Isto implica o envio de um XCBFSecurityToken para ser tratado pelo STS.
2. STS verifica credencial	O STS recebe o RST (RequestSecurityToken) e o <i>token</i> biométrico, que contém a informação necessária para escolher o algoritmo de comparação. O STS busca o perfil biométrico do usuário no banco de dados e efetua o processo de verificação.
3. STS obtém atributos	O STS, agora atuando como autoridade de atributos, recupera os atributos desejados do usuário em um repositório de atributos.
4. O STS devolve as asserções	O STS devolve uma mensagem ao agente cliente, contendo uma RSTR (RequestSecurityTokenResponse), que contém as credenciais necessárias para que o agente cliente possa executar o serviço. A autenticidade da resposta é garantida por meio de assinaturas digitais e a resposta pode conter informações adicionais, como o tempo de vida das credenciais enviadas e mecanismos de proteção contra ataque de mensagens antigas.
5. Agente cliente invoca o serviço	O agente cliente efetua a requisição ao serviço, enviando também as credenciais obtidas junto ao STS. A invocação é interceptada (por um <i>handler</i>) para o devido processo de autorização.
6. Consulta do PEP	O PEP monta um pedido XACML e encaminha o pedido ao PDP, para que este decida sobre a tentativa de acesso.
7. Decisão do PDP	O PDP analisa os atributos relacionados ao usuário e ao recurso e consulta a política de autorização associada ao serviço. Tomada a decisão, o PDP monta uma resposta XACML e envia a mesma para o PEP.
8. Execução	O PEP então aplica a decisão de autorização do PDP, autorizando ou negando a execução do serviço.

Tabela 1. Dinâmica de funcionamento.

Um importante aspecto considerado na proposta é o **armazenamento dos perfis biométricos**, que é centralizado. Esta decisão possui justificativas estreitamente ligadas ao perfil de utilização do canal *web banking*. Dentre a totalidade dos clientes do banco, apenas uma parcela se vale destes serviços. Assim, não se justifica a adoção de métodos custosos ou inovadores para a distribuição dos perfis biométricos para os usuários. A criação e gerenciamento, pelo próprio banco, de um banco de dados de perfis biométricos dos usuários se mostra a alternativa mais eficaz. O armazenamento de perfis biométricos desperta preocupações com privacidade e segurança, uma vez que uma característica biométrica não pode ser revogada. Para evitar tais problemas, pode-se utilizar uma técnica conhecida como **biometria cancelável** [Bolle et al. 2004], em que uma transformação não reversível é aplicada sobre os dados biométricos de forma a proteger a característica biométrica original. Em caso de comprometimento, o perfil armazenado pode ser cancelado, e outra variante pode ser criada por meio de outra transformação. Neste modelo, aplica-se uma transformação ao perfil colhido durante o processo de registro dos usuários. A mesma transformação é aplicada no lado do usuário (pelo agente cliente) durante o processo de autenticação. Desta forma, os dados biométricos ficam protegidos tanto no banco de dados de perfis quanto durante a sua transmissão.

5.3. Implementação e Resultados

A aplicabilidade do modelo proposto foi verificada através da implementação de um protótipo, que compreende uma aplicação simplificada de *web banking* e um serviço de autenticação biométrica construídos sobre um suporte de Serviços Web (figura 8). O protótipo segue a mesma dinâmica do modelo: o cliente procura realizar sua autenticação biométrica junto ao STS e recebe deste uma asserção SAML, que é posteriormente apresentada ao serviço que implementa transações bancárias. A implementação utiliza amplamente ferramentas de código aberto, tais como:

- Apache (<http://ws.apache.org/>): servidor HTTP;
- Tomcat (<http://tomcat.apache.org/>): extensão do Apache para *servlets* Java;
- Axis (<http://ws.apache.org/axis/>): implementação de SOAP;
- WSS4J (<http://ws.apache.org/wss4j/>): implementação do WS-Security, que permite assinatura e cifragem de mensagens SOAP e possui um STS que emite credenciais (*tokens*) nos formatos UsernameToken, TimeStamp e SAML.

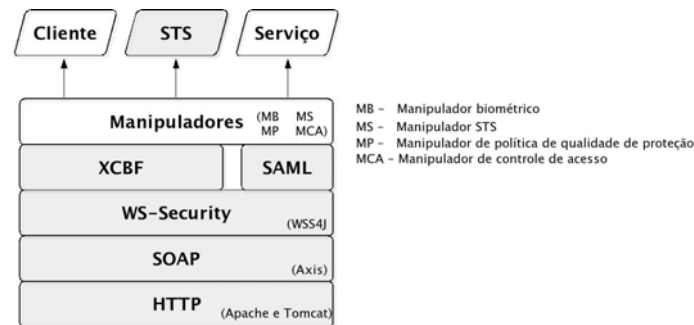


Figura 8. Arquitetura do protótipo, com módulos utilizados (fundo cinza) e módulos implementados (fundo branco).

Uma característica do Axis que foi bastante usada na construção do protótipo é o uso de **manipuladores** (*handlers*), que são módulos responsáveis por manipular tipos específicos de objetos contidos em uma mensagem SOAP. No lado do cliente, o protótipo consiste em um *applet* Java e um manipulador biométrico. O *applet* é responsável por solicitar os dados de autenticação (agência/conta e credencial biométrica) e invocar as operações bancárias (saldo, extrato, transferências).

Para contornar a dificuldade de acesso a um dispositivo real de aquisição de impressões digitais, gerou-se um conjunto de amostras para teste usando o SFinGe.³ Assim, para se autenticar, o usuário simplesmente escolhe uma das digitais geradas previamente. O manipulador biométrico do agente cliente se encarrega de processar a impressão digital selecionada e encapsular o resultado desse processamento em XCBF. O processamento da digital consiste em extrair características notáveis usadas para comparação (chamadas **minúcias**) e aplicar uma transformação sobre essas características. As minúcias são representadas por registros que contêm as informações de tipo de minúcia, localização espacial 2D (x,y) e de orientação (θ). Elas são extraídas da imagem da digital usando o MINDTCT, uma ferramenta do pacote NFIS.⁴ Após a extração, as minúcias passam pela

³Synthetic Fingerprint Generator, disponibilizado pela Universidade de Bolonha em <http://biolab.csr.unibo.it/>.

⁴NIST Fingerprint Image Software, disponível em <http://fingerprint.nist.gov/NFIS/>.

transformação usada para garantir a revogabilidade dos perfis, conforme apresentado na seção 5.2. No protótipo, a transformação adotada consiste em uma rotação e translação aplicadas às minúcias: para cada minúcia (x, y, θ) é acrescentada uma translação (Δ_x, Δ_y) e uma rotação Δ_θ . Embora esta seja uma transformação reversível (e, portanto, não aplicável na prática), ela é suficiente para nossos propósitos.

A implementação do STS com suporte a credenciais biométricas foi baseada no STS previamente desenvolvido no nosso grupo de pesquisa, que disponibilizava manipuladores para troca de mensagens entre o cliente e o STS, de cifragem e assinatura de mensagens, de política de qualidade de proteção e de controle de acesso, incorporando as funções do PEP e do PDP [Camargo 2006]. A esta base de código existente foi acrescentado um manipulador para credenciais biométricas, desenvolvido especificamente para este fim. Este manipulador é responsável por extrair a impressão digital (representada por suas minúcias) encapsulada em um objeto XCBF e efetuar a comparação biométrica com o perfil armazenado. Esta comparação é feita invocando o outra ferramenta do pacote NFIS citado no parágrafo anterior, o BOZORTH3 que, operando em modo de verificação, é capaz de calcular um escore de similaridade entre dois conjuntos de minúcias. No nosso protótipo, considerou-se que duas impressões são coincidentes quando a similaridade entre elas é igual ou superior a 98%. Os perfis ficam guardados em um repositório simples, tendo sofrido a mesma transformação de rotação e translação aplicada pelo manipulador biométrico do cliente antes de serem armazenados.

Os testes realizados tiveram por objetivo uma análise dos resultados considerando a latência média introduzida pelo processamento das mensagens por parte dos manipuladores. Os resultados, que podem ser visualizados na tabela 2, foram obtidos após o processamento de 50 interações com o usuário, em 5 datas distintas. Os tempos foram medidos entre o envio da mensagem SOAP para autenticação no STS e a recepção da resposta do serviço pelo agente do usuário, e foram obtidos por meio de pesquisa nos registros em um arquivo de *log* centralizado na máquina A. O esquema de *round trip* foi utilizado para calcular os tempos. Os testes foram realizados em uma rede local Fast

Tipo de objeto biométrico	Latência média (ms)
Descoberto	340
Cifrado	437
Cifrado e assinado	527

Tabela 2. Resultados - latência média na troca de mensagens.

Ethernet de 100Mbps, com três computadores dedicados: (A) Pentium IV 2.4 GHz com 512 MB de memória RAM, tendo como sistema operacional o Windows XP; (B) Pentium IV 3 GHz com 1GB de memória RAM e sistema operacional GNU/Linux; e, (C) Athlon XP 2.6 GHz com 512 MB de memória RAM e sistema operacional GNU/Linux. Todas as máquinas se valeram de J2SDK v.1.5.0-01, do servidor de aplicações Tomcat v.5.5 e do pacote Axis v.1.3. O cliente foi hospedado na máquina A, o provedor de serviços foi hospedado na máquina B e o STS foi hospedado na máquina C.

6. Trabalhos relacionados e considerações

A literatura acadêmica envolvendo soluções amplas para os sistemas de banco eletrônico em geral e *web banking* em particular, se mostra limitada. A maioria dos documentos

disponíveis sobre o assunto consiste em artigos na imprensa, seguindo um estilo informal. Uma das exceções é [Shan 2004], onde o autor examina o ambiente computacional bancário e discute como os Serviços Web podem ser aplicados em sistemas de *e-banking*. Entretanto, a discussão se restringe a aspectos genéricos, sem descrever uma arquitetura de implementação nem detalhar a implementação de processos específicos, como a autenticação de usuários. Embora a capacidade de interoperabilidade proporcionada pela utilização de Serviços Web seja extremamente valiosa, esta tecnologia ainda está imatura e em constante evolução, o que cria dificuldades para os usuários finais para um planejamento realista de larga aplicação desta tecnologia.

Em [Weaver 2004] encontramos socorro à nossa decisão de utilização de Serviços Web, pois ele percebe esta tecnologia como o meio preferencial para conectar aplicações dentro e fora da organização. Ele sugere ainda que o grau de confiança na tecnologia de autenticação subjacente seja representado numericamente, através do que ele chama de nível de confiança (NC): quanto mais confiável fosse a tecnologia, maior seria o seu NC. Por exemplo, a biometria baseada na íris ocular teria um NC maior do que a biometria usando impressões digitais (ao menos considerando-se a tecnologia atual). No nosso modelo, o NC poderia ser associado ao *token* de autenticação emitido pelo STS, permitindo assim decisões de autorização baseadas em níveis de confiança. Contudo, a abordagem de Weaver é bastante genérica e focada na segurança de dados distribuídos, não contemplando análise mais aprofundada do canal *web banking* ou das tecnologias biométricas disponíveis.

A utilização das tecnologias biométricas para autenticação de usuários no canal *web banking* ainda é um assunto aberto para discussões. Um sistema para autenticação biométrica através da *web*, usando como característica biométrica o formato da mão é descrito em [Jain et al. 1998]. Em vez de uma arquitetura distribuída como a proposta neste artigo, os autores consideram uma arquitetura centralizada, onde um único servidor *web* se encarrega de autenticação, autorização e do provimento do serviço. Além disso, não há preocupação com a proteção dos perfis biométricos armazenados, apenas com a dos perfis em trânsito, que são cifrados.

A introdução de um método de autenticação biométrico pode requerer um contato presencial com cada cliente, para capturar inicialmente o perfil. Ademais, pode ser necessária a presença do cliente para atualização dos perfis biométricos, com o passar do tempo. Alguns clientes podem ser incapazes de produzir um identificador biométrico, temporariamente ou permanentemente, devido a alguma deficiência natural ou adquirida. É sugestão para um trabalho futuro a extensão do modelo aqui proposto, para um modelo mais amplo, que represente uma aplicação de *web banking* com autenticação alternativa baseada em uma credencial obrigatória de conhecimento (como uma senha), o que poderia atender melhor as necessidades imediatas dos bancos de varejo.

7. Conclusão

Este trabalho apresentou uma visão resumida do ambiente computacional de um banco de varejo típico e do canal *web banking* em particular, demonstrando que sua complexidade de plataforma e dependência de sistemas legados clamam por soluções que proporcionem interoperabilidade, como é o caso dos Serviços Web. Apresentamos ainda o funcionamento de um sistema biométrico conceitual, as tecnologias biométricas mais comuns e os

padrões internacionais para as mesmas. Um modelo para a autenticação em *web banking* por credenciais biométricas suportadas pelos padrões de Serviços Web foi apresentado, detalhado, e teve um protótipo implementado. A extensão do modelo estudado neste trabalho, que se vale apenas de autenticação biométrica, para um modelo mais amplo, é sugestão para um trabalho futuro. Este modelo mais amplo poderia ser usado para representar uma aplicação de *web banking* com autenticação baseada em um conjunto mais amplo de credenciais, o que poderia atender melhor as necessidades imediatas dos bancos de varejo.

Agradecimentos

Este trabalho faz parte do projeto “Infra-estrutura de Segurança para Aplicações Distribuídas Orientadas a Serviço”, financiado pelo CNPq (550114/2005-0).

Referências

- ANSI (2003). Biometric information management and security for the financial services industry. Standard X9.84-2003, American National Standards Institute.
- Bolle, R. M., Connell, J. H., Pankanti, S., Ratha, N. K., and Senior, A. W. (2004). *Guide to Biometrics*. Springer Professional Computing, 1st edition.
- Camargo, E. T. (2006). Transposição de autenticação e de autorização em arquiteturas orientadas a serviços. Dissertação de mestrado, PGEEL/UFSC, Florianópolis, SC.
- Costa, L. R., Obelheiro, R. R., and Fraga, J. S. (2006). Introdução aos sistemas biométricos. In *Minicursos do SBSEG 2006*, Santos, SP.
- Febraban (2006). Setor bancário em números. Technical report, Federação Brasileira de Bancos, Disponível em <http://www.febraban.org.br>.
- Gupta, M., Rao, R., and Upadhyaya, S. (2004). Electronic Banking and Information Assurance Issues. *Journal of Organizational and End User Computing*, 16(3):1–21.
- Jain, A. K., Prabhakar, S., and Ross, A. (1998). Biometrics-based web access. Technical Report MSU-CPS-98-33, Michigan State University.
- Kearney, P., Chapman, J., Edwards, N., Gifford, M., and He, L. (2004). An overview of Web Services security. *BT Technology Journal*, 22(1):27–42.
- Mello, E. R., Wangham, M. S., Fraga, J. S., and Camargo, E. S. (2006). Segurança em serviços web. In *Minicursos do SBSEG 2006*, Santos, SP.
- NIST (2001). CBEFF - Common Biometric Exchange File Format. Technical Report NISTIR 6529, National Institute of Standards and Technology, USA.
- Shan, T. (2004). Building a service-oriented eBanking platform. *Proceedings of the IEEE International Conference on Services Computing (SCC'04)*, pages 237–244.
- Skliara, M., Pomportsis, A., and Obaidat, M. (2003). A framework for the design of bank communications systems. *Computer Communications*, 26(15):1775–1781.
- Weaver, A. (2004). Enforcing distributed data security via Web Services. *Proceedings of the IEEE International Workshop on Factory Communication Systems*, pages 397–402.
- WS-Trust (2005). *Web Services Trust Language (WS-Trust)*. <http://msdn.microsoft.com/library/en-us/dnglobspec/html/WS-Trust.asp>.
- Yavatkar, R., Pendarakis, D., and Guerin, R. (2000). A framework for policy-based admission control. IETF RFC 2753.